ISMAEL VALENZUELA

My ERP got hacked
An Introduction to Computer Forensics

Difficulty

The System Administrator knew something was wrong when he saw there was an additional user account on the Web-based Enterprise Resource Planning (ERP) system that he administered. He kept the system updated and patched, but he now suspects that the system has been hacked and compromised. Now, as a computer forensic investigator, you will have to find out if there was any unauthorized access, how it happened and what was the extent of the damage.

WHAT YOU WILL LEARN...

How to best react to incidents while collecting volatile and non-volatile evidence

How to investigate security breaches and analyze data without modifying it

How to create event time lines, recover data from unallocated space, extract evidence from the registry and how to parse windows event logs

WHAT YOU SHOULD KNOW...

Windows and Linux System Administration

Intrusion and hacker techniques

NTFS file system essentials

That was the scenario introduced by the Third Forensic Challenge, organized by the UNAM-CERT (Mexico) in 2006. Based on that scenario and using a live image of the Windows 2003 Server, which hosted the ERP application, we will set up a forensic laboratory that will be used throughout this article to illustrate and practice the methods, techniques and tools used to identify, collect, preserve and investigate the digital evidence found during the course of a computer forensic investigation.

Introduction

Scenarios like the one described represents just one of the countless variety of security incidents that can trigger a computer forensic investigation. From employee Internet abuse and unauthorized disclosure of corporate data, to industrial espionage and more general criminal cases, computer forensics techniques can be valuable in a wide range of situations, providing insight into how past events have occurred.

But, piecing together the puzzle of what happened on a system is not a straightforward process. It requires the use of advanced techniques and tools to collect volatile and non-volatile data, perform data recovery, create event time lines and provide accurate reports, among others. Nevertheless, the overall forensic investigation methodology will remain the same from case to case, regardless of what tools you use. This process is often divided into the following phases:

- Acquire the evidence without altering or damaging the original data
- Authenticate the recovered evidence and verify that is the same as the originally seized data
- Investigate and analyze the data without modifying it
- Report the results
- Maintain a Chain of Custody of all evidence

To envision this process best, we will play the role of a computer forensic professional in charge of the investigation. It is important to understand that it is not the purpose of this exercise to detail the solution to this challenge (that is already covered by the reports produced by the participants and available on their website), but rather to provide hands-on practice using a ready-to-use image that anyone can download from the Internet. Besides, the image does not contain any real data, since it was specially built for the forensic challenge.

One word of caution. Before we begin, it is necessary to realize that computer forensics is much more than just a set of techniques and tools. It is a complex, technologically fast evolving field that requires the use of a proven, effective methodology and trained professionals capable of dealing with high-level technical and legal issues. This is especially true when the investigation results are expected to be used in a court of law (which should be assumed in every investigation). Also, keep in mind the possible consequences; make sure you

have the proper authority and approval before initiating any real investigation and that the appropriate personnel (i.e., human resources, legal and even law enforcement, if necessary) are notified, as soon as possible if a crime has been identified.

If in doubt, ask for additional professional assistance. Making one simple mistake can completely nullify the entire case in court. Hiring a qualified third-party expert will ensure safe handling of the evidence and will establish a Chain of Custody that guarantees additional layers of protection. It will also help to refute accusations of evidence tampering or spoliation, which may save both you and your employer serious trouble.

Setting the Lab

You can re-create and do the hands-on exercises described in this article using the Windows 2003 disk image available at *ftp://escitala.seguridad.unam.mx/reto/windows2003.img.gz* (4.9 GB). (Also available at *ftp://ftp.rediris.es/rediris/cert/reto/3.0/windows2003.img.gz*).

The image is a bit-for-bit copy of the main partition (also called a raw image) gathered using 'data definition', also known as *'dd'*a small utility that reads input files block by block. When used to acquire a disk device, *dd* also captures the blocks of data that are marked for deletion by the OS. That information is extremely useful in any forensic investigation.

To analyze and investigate the evidence, we will use a combined Linux/Windows forensics laboratory environment. As for the Linux environment, we will use the *SIFT Forensic Workstation*, which is a VMWare Appliance containing pre-configured forensics tools and freely available from the SANS Forensic Blog at *http://forensics.sans.org/community/downloads/* (1.35 GB) and created by Rob Lee. Linux is a good choice for a portable forensic workstation since it supports many different file systems from different operating systems (i.e., FAT, NTFS, HFS, UFS, Ext2/3 and others).

To mount the Windows 2003 image on your forensic workstation, change to the folder where the image has been copied to and type the following:

- *ntfs-3g windows2003.img /mnt/hack/ -o loop,ro*

That will mount the disk image into READ-ONLY mode, and will let you browse the original filesystem both locally and through Samba using a READ-ONLY fileshare.

As for the Windows environment, all of the tools referenced in this article can be downloaded from the links included in the On the 'Net frame. Those tools will work on the off-line image mounted on the Linux workstation and shared using Samba. Since you already mounted your image into read-only mode, you will be able to examine the filesystem and run any windows programs on it (i.e., antivirus, registry viewers, etc...) without altering the evidence.

While instructions on how to set up a virtual network in VMWare are out of the scope of this article, make sure both of your computers are on an *air-gapped* network, with the virtual machines network adapters set to Host-only to minimize the risk of altering the evidence.

Although we will perform most of our investigation on the off-line image, it is always handy to have a live image available. LiveView *(http://liveview.sourceforge.net/faq.html)* can do this, allowing disk images or physical drives to be booted up in a virtual machine and examined in a forensically sound manner. We will use it to create a bootable image of the compromised Windows 2003 server, so we can see how to perform initial incident response on live systems, recreate attacks, run vulnerability assessments, etc... (You might need to use the *Offline NT Password & Registry Editor* utility to reset the local Administrator's password, available at *http://home.eunet.no/pnordahl/ntpasswd/*)

Last but not least, we will add a HELIX CD to our forensic tool arsenal. HELIX is a Knoppix based bootable Linux Distribution CD created to obtain live data and forensic images from running and powered off systems. It contains most of the tools you might need during an incident response phase and it is available from *http://helix.e-fense.com/Download.php* (Note that at the time of writing this article Helix changed its licensing model and now the *Helix2008R1.iso* file is not available for download from the e-fense site. However, this image is still available from other sites as well as all the tools that includes which are referenced in the *On the Net* section. In any case, always read and adhere to the vendor's license terms before installing and using any software to avoid violations.)

I've Been Hacked, Now What? – Initial Response

Being hacked is not a pleasant situation. Our ERP may have been compromised and the last thing we want is to have our corporate data in the hands of our competitors. It is then vital to keep calm and to follow a sound forensic methodology, as you do not know whether the evidence you are gathering might be ending up in court or not.

First thing you need to do is to verify that you really have an incident and try to minimize our interference on the suspected system. I say *minimize* because you cannot

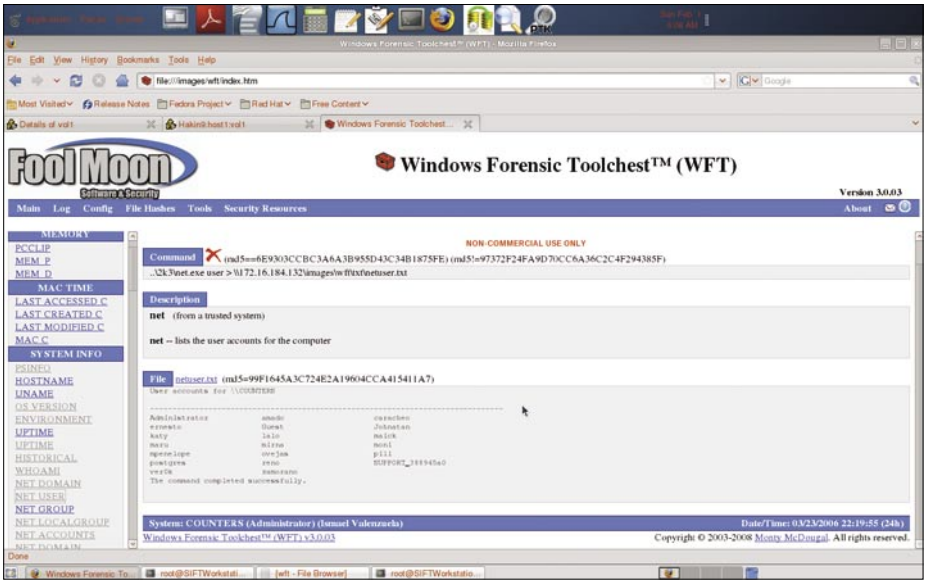

Figure 1. *A WFT report showing security-relevant information from the system*

interact with a live system without having some effect on it. Ever heard something about *Locard's* while watching CSI? Locard's exchange principle basically states that when any two objects come into contact, there is always transference of material from each object onto the other. System logs recording hacker actions and data left on hard disks in unallocated sectors are examples of Locard's principle in action. Also, while performing incident response the system will continue to change even if you do not touch the keyboard at all. It is usually during this phase when you must not only verify the incident, but also begin to collect all the necessary evidence. So what is evidence and where can we find it? Evidence is anything you can use to prove or disprove a fact. In the context of computer forensics, evidence can be found at many different layers: network (firewalls, IDS, routers...), operating system, system and application logs, databases, applications, peripherals, removable media (CD/DVD, USB...), and of course human testimony. Ensuring that you have access and gather all the available evidence is paramount at this stage.

As our incident is concerned, we do not have access to any evidence outside the ERP server, so our forensic investigation will be restricted to that one particular system.

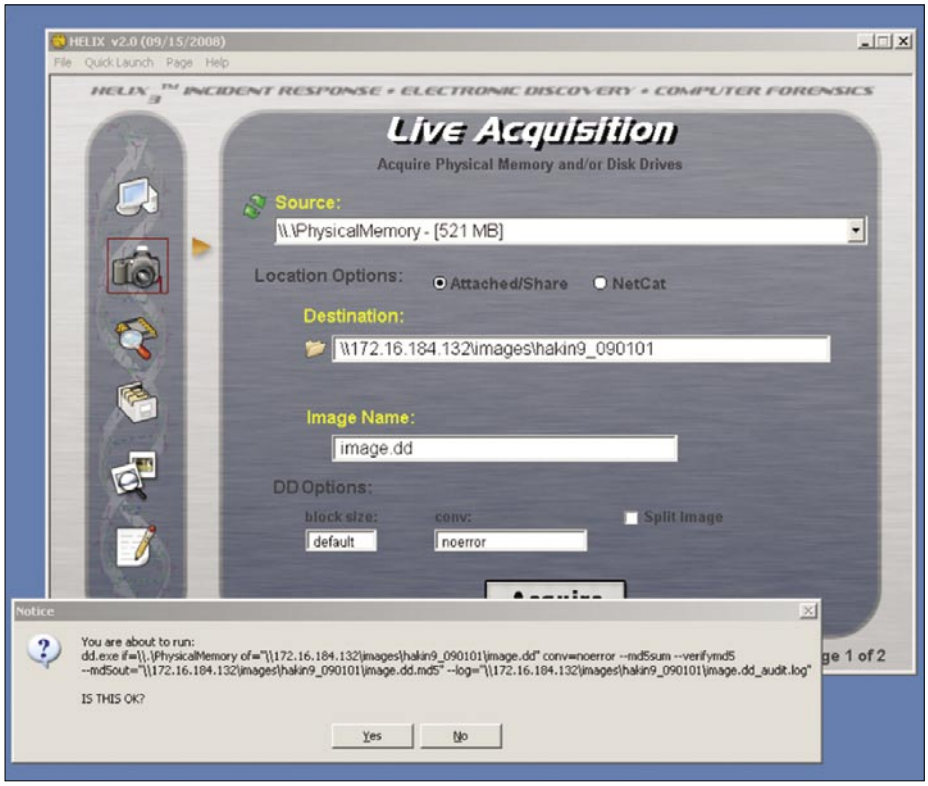

Figure 2. *Acquiring physical memory using Helix GU*

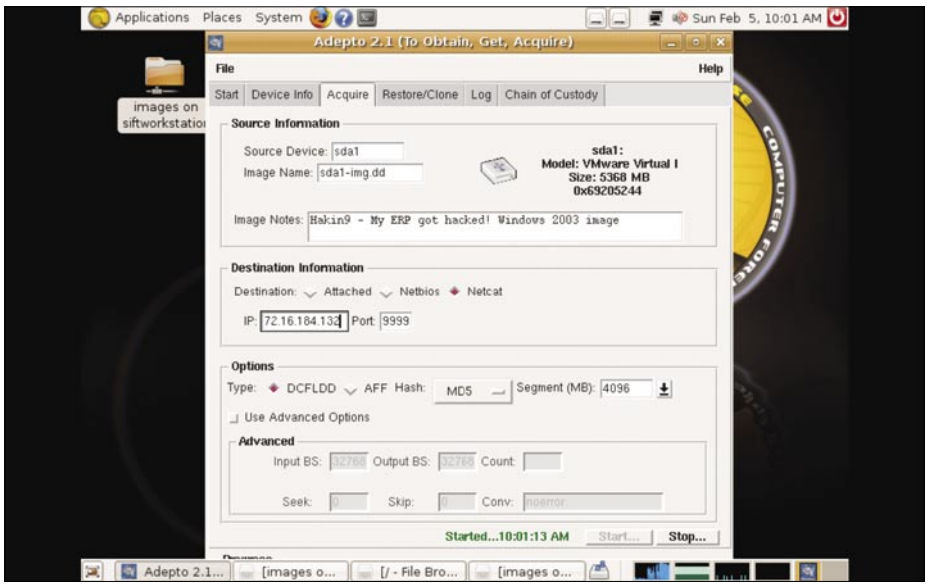

Figure 3. *Disk acquisition using Adepto on Helix*

Dead or Alive

The process to gather evidence will depend on whether the suspect system is actually live and running or has been powered off during the incident response phase. Many people would follow the 'traditional' approach and just pull the plug as soon as the incident was detected. Though this method is great to preserve data on the disk, you will also destroy any chances to find volatile data or running processes in memory. This process is no longer acceptable and today most computer forensic professionals recognize the value of volatile data and many are obtaining memory captures during evidence seizure.

As many attackers these days only have their tools running in memory, it becomes crucial to ensure that evidence is not accidentally erased if you encounter a live system. Meterpreter, the Metasploit payload is an example of one of those attacking tools that does not leave any traces on the hard drive, but rather runs exclusively in the computer's memory.

Thus, if the system we are to analyse is live, we must ensure that the evidence is collected in order of most volatile to least.

The overall process would be:

- Gather network status and connections
- Take the system off the network
- Gather running processes and system memory
- Pull the cord
- Acquire hard drive and removable media (floppies, USB drives, etc...)
- Take photographs of hardware, systems, rooms, etc... if necessary
- Continue with the verification of the incident by looking at co-hosted machines, IDS logs, firewall logs, witness testimony, etc...
- Document everything

Where the corporate policy and the local legal regulations allow, it might be also recommended to place a wiretap

to capture ongoing network traffic. Also, should your organization have a written Incident Response Plan or any other applicable procedures, make sure you follow them. For example, in certain sectors where 'pulling the cable' is not an option, alternative procedures must be followed.

On the other hand, if all you can find is a dead system ignore the first three steps and start right off with step 5.

When the System is up and Running

Back to our ERP, we know that the images we have available were taken by the system administrator after the system was powered off. So all the information that was in memory has been effectively destroyed. However, for the sake of illustrating how to perform an initial forensic response we will assume that the system was up and running, and that the forensic investigator was the first responder. Later investigation and analysis will be performed on the off-line image only.

To automate the collection of useful information from the live ERP system, we will use the latest version of the Windows Forensic Toolchest (*www.foolmoon.net/security*) that can be found on the Helix CD.

It is always recommended that you run your tools from a clean CD, as you do not know whether the attacker might have compromised the server's binaries. Thus, we insert the Helix CD on the suspect machine (or simply use the Helix ISO file as a CD on your virtual machine) open a clean console from it, in this particular case from *D:\IR\2k3\cmd.exe, and type*:

- *wft.exe -case hakin9 -cfg wft.cfg -drive auto -dst \172.16.184.131\forensics\hakin9\wft\ -hash md5 -name Ismael Valenzuela -nowrite -os auto -prunetools -shell cmd2k3.exe -toolpath ..*

That command will use the settings in wft.cfg and collect all security relevant information from the server, wrapping the output of several command line tools (from sysinternals, Foundstone and others) into a well-formatted HTML report, using the settings stored in wft.cfg, as shown in Figure 1. The modifiers force WFT to create an md5 hash, to include your name on the report, and will not run any executable that writes to the machine (remember Locard's?).

Though we could have used Window's built-in commands like netstat, date, time, at and others like pslist, psinfo and fport from sysinternals, WFT has automated that for us, using a command line tool from a CD like Helix. Other ways to achieve this might involve the use of netcat over an SSH channel or cryptcat (netcat over SSL). WFT can also be executed from the GUI thorough the Helix CD.

System Memory Acquisition

To acquire the physical memory, start Helix from the CD on the suspect machine and

Listing 1. *Excerpt from running RegRipper on the SYSTEM registry file*

```
ComputerName = COUNTERS
----------------------------------------
ControlSet001\Control\Windows key, ShutdownTime value
ControlSet001\Control\Windows
LastWrite Time Sun Feb  5 23:44:32 2006 (UTC)
  ShutdownTime = Sun Feb  5 23:44:32 2006 (UTC)
----------------------------------------
ShutdownCount
ControlSet001\Control\Watchdog\Display
LastWrite Time Wed Jan 25 21:05:34 2006 (UTC)

ShutdownCount value not found.
----------------------------------------
TimeZoneInformation key
ControlSet001\Control\TimeZoneInformation
LastWrite Time Thu Feb  2 01:39:50 2006 (UTC)
  DaylightName   -> Pacific Daylight Time
  StandardName   -> Pacific Standard Time
  Bias           -> 480 (8 hours)
  ActiveTimeBias -> 480 (8 hours)
----------------------------------------
Windows Firewall Configuration
ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\StandardProfile
LastWrite Time Fri Jan 27 02:13:41 2006 (UTC)
          DoNotAllowExceptions -> 0
          EnableFirewall -> 1
          DisableNotifications -> 0
ControlSet001\Services\SharedAccess\Parameters\FirewallPolicy\StandardProfile\
                      GloballyOpenPorts\List
LastWrite Time Sat Feb  4 22:49:37 2006 (UTC)
          1900:UDP -> 1900:UDP:LocalSubNet:Enabled:@xpsp2res.dll,-22007
          2869:TCP -> 2869:TCP:LocalSubNet:Enabled:@xpsp2res.dll,-22008
          137:UDP -> 137:UDP:LocalSubNet:Enabled:@xpsp2res.dll,-22001
          445:TCP -> 445:TCP:LocalSubNet:Enabled:@xpsp2res.dll,-22005
          138:UDP -> 138:UDP:LocalSubNet:Enabled:@xpsp2res.dll,-22002
          3389:TCP -> 3389:TCP:*:Enabled:@xpsp2res.dll,-22009
          139:TCP -> 139:TCP:LocalSubNet:Enabled:@xpsp2res.dll,-22004
          5432:TCP -> 5432:TCP:*:Enabled:postgrest
----------------------------------------
USBStor
ControlSet001\Enum\USBStor

Disk&Ven_Kingston&Prod_DataTraveler_2.0&Rev_1.04 [Sun Feb  5 22:24:55 2006]
  S/N: 08C0B35051C1F002&0 [Fri Jan 27 01:57:49 2006]
    FriendlyName  : Kingston DataTraveler 2.0 USB Device
    ParentIdPrefix: 7&32f4468f&0
  S/N: 08F0B35051432FC2&0 [Sun Feb  5 22:25:00 2006]
    FriendlyName  : Kingston DataTraveler 2.0 USB Device
    ParentIdPrefix: 7&41d2787&0
  S/N: 09E0B350E0F2A50C&0 [Sat Feb  4 22:58:51 2006]
    FriendlyName  : Kingston DataTraveler 2.0 USB Device
    ParentIdPrefix: 7&24ec3fd&0

Disk&Ven_SanDisk&Prod_Cruzer_Mini&Rev_0.2 [Thu Jan 26 19:43:42 2006]
  S/N: SNDK1EDA752F2C906502&0 [Thu Jan 26 19:43:48 2006]
    FriendlyName  : SanDisk Cruzer Mini USB Device
    ParentIdPrefix: 7&35d51612&0
```

Listing 2. *Applications listed in the SOFTWARE registry file*

```
Uninstall
Microsoft\Windows\CurrentVersion\Uninstall
Sun Feb  5 21:14:35 2006 (UTC)
          MPlayer2
Sat Feb  4 22:46:58 2006 (UTC)
          PostgreSQL 8.1
Sat Feb  4 02:05:29 2006 (UTC)
          MSN Messenger 7.5
Sat Feb  4 01:52:54 2006 (UTC)
          Mozilla Firefox (1.5.0.1)
Fri Jan 27 02:43:01 2006 (UTC)
          MySQL Administrator 1.1
Fri Jan 27 02:39:50 2006 (UTC)
          MySQL Server 4.1
Fri Jan 27 02:04:01 2006 (UTC)
          PHP 4.4.2
Fri Jan 27 02:00:42 2006 (UTC)
          Apache HTTP Server 1.3.34
Thu Jan 26 22:02:34 2006 (UTC)
          Security Update for Windows Server 2003 (KB905414)
Thu Jan 26 22:02:16 2006 (UTC)
          Security Update for Windows Server 2003 (KB890046)
          Security Update for Windows Server 2003 (KB896428)
          Security Update for Windows Server 2003 (KB899587)
Thu Jan 26 22:00:38 2006 (UTC)
          Security Update for Windows Server 2003 (KB901017)
Thu Jan 26 22:00:16 2006 (UTC)
          Security Update for Windows Server 2003 (KB899589)
Thu Jan 26 21:59:39 2006 (UTC)
          Security Update for Windows Server 2003 (KB908519)
Thu Jan 26 21:59:17 2006 (UTC)
          Security Update for Windows Server 2003 (KB903235)
Thu Jan 26 21:58:42 2006 (UTC)
          Security Update for Windows Server 2003 (KB901214)
          Security Update for Windows Server 2003 (KB902400)
Thu Jan 26 21:56:03 2006 (UTC)
          Update for Windows Server 2003 (KB896727)
Thu Jan 26 21:55:11 2006 (UTC)
          Security Update for Windows Server 2003 (KB896688)
Thu Jan 26 21:54:22 2006 (UTC)
          Security Update for Windows Server 2003 (KB896358)
          Security Update for Windows Server 2003 (KB896422)
          Security Update for Windows Server 2003 (KB896424)
Thu Jan 26 06:42:36 2006 (UTC)
          DXM_Runtime
Thu Jan 26 06:42:12 2006 (UTC)
          Branding
Thu Jan 26 06:39:34 2006 (UTC)
          PCHealth
Thu Jan 26 06:39:31 2006 (UTC)
          AddressBook
          DirectAnimation
          NetMeeting
          OutlookExpress
Thu Jan 26 06:39:30 2006 (UTC)
          ICW
Thu Jan 26 06:39:25 2006 (UTC)
          DirectDrawEx
          Fontcore
          IE40
          IE4Data
          IE5BAKEX
          IEData
          MobileOptionPack
          SchedulingAgent
Thu Jan 26 06:26:49 2006 (UTC)
          Connection Manager
```

go to the Acquisition menu. Choose the physical memory as the source. We will use the shared *image* folder on our Linux Forensic workstation as the destination. Before the tool starts the job you will see a pop up alert showing the command line that Helix will run, as shown in Figure 2.

Make sure you are logged on as Administrator or the tool will not be able to create the dump. As you can see, Helix uses *dd* to acquire the physical memory too, although you can find other popular command-line tools like *mdd* and *win32dd* under the *D:\IR\RAM directory*.

Coupled with the ability of sysinternal's psexec to execute programs on remote systems these are very powerful tools.

Hard Drive Imaging

Once you have acquired the most volatile evidence from the system, it is time to image the hard drive and any other media like floppies, USB drives, etc...

When doing so, there are two things you have to avoid. One is imaging the hard drive of a live system. Remember we are dealing with a machine that is suspected to be compromised, so you cannot rely on the operating system. Also, imagine an application that modifies an on-disk file. While it writes partial modified state to the file, the rest remains in system RAM, and it is only written to the file system when the application is closed. Thus, while applications are running and files are being modified on disk, the file system is indeed in an inconsistent state.

Second thing you must be aware is that the hard drive is written to every time a system is gracefully shutdown, cleaning the file system of temporary files. Depending on the system configuration this can include the valuable *pagefile.sys* file, which stores those frames of memory that will not fit into physical memory. Data stored in the paging file can include cached passwords, fragments of open files and processes, unencrypted data and even memory resident malware, among others. I bet you agree this is useful for our forensic investigation, so, if the policies allow, please PULL THE PLUG now!

Following the golden rule of electronic evidence ensure that first thing that is accomplished, before any analysis starts, is to have an exact, bitwise copy of the original media. Once the imaging is completed, a

digital fingerprint, typically an md5 or sha1 hash, should be generated on both the acquired and original media, to authenticate that the two images are identical.

The images can be acquired either with the use of software or hardware tools. The latter often includes hardware write blockers and HD duplicators that are mostly used by computer forensic professionals who seek both reliability and maximum duplication speeds.

Making use of the tools available in our lab, we will boot the suspect computer from the Helix CD and run *dd* to image the disk over the network using either netcat, a fileshare, or an attached USB drive. Although several tools like Adepto can use compression, make sure you have enough free space and if everything goes well, the image will be an exact copy of the original.

To assist us in complex *dd* commands, Helix includes a GUI interface to *dd* called Adepto. The acquisition is similar to that of the physical memory: select the drive you wish to make a dump of and then select your destination. Choose your hash algorithm and after the dump is finished, go to the *Chain of Custody* tab to save the dump report as a PDF. Then verify the hashes using md5sum and sha1sum, whichever you used initially.

Now that the volatile and non-volatile evidences have been acquired, the system will be turned off and original disks removed, labeled and kept safe to preserve their integrity and logged in a Chain of Custody report. The original disks should be locked away in a sealed, tamper-proof bags to preserve their integrity and the Chain of Custody.

However, as our forensic case is concerned, we do not have access to the volatile evidence. Remember we have created a bootable image using the only evidence that the challenge provides, a raw *dd* image of the suspect hard drive. All the volatile evidence was destroyed when the administrator powered the system off. Thus, all the analysis will be performed on the off-line system only, although we might use our bootable image to confirm our findings.

Investigation and Analysis

To start with our initial analysis we need to mount the disk image to our forensic workstation using the loopback interface. To do so, follow the instructions on *Settings the Lab* section and ensure that the 'ro' (read-only) option is specified. Now you can browse the Windows disk image from your trusted system.

OK, so we have a 4.9 GB image to examine and a lot of data to look at. The big question now is... where do we start?

Think as an Investigator

You have probably heard many times that it is necessary to think like a hacker to be a successful penetration tester. Conducting a successful forensic investigation requires a proper mindset too, that is, to think as an investigator. It is part of this mindset to:

- Identify what data is needed to put together a complete picture of what happened, how it happened and who did it?
- Think of what kind of system are you dealing with, what was it used for, who used it and how was it configured?
- Find different ways to prove the same things.
- Take careful notes as you go through the investigation processes, especially if it is thought this case might end up in court.
- Validate, sign and encrypt each piece of evidence so it can proved that it was not tampered with and follow the Chain of Custody reporting requirements.
- Prove all of the hypotheses to yourself. At the end of the day to might end up doing so before a judge, a jury and a defense attorney that will question everything you have said and done.
- Remember, the case might not go to court for years, so do not rely on your memory, rely on your detailed notes. The defending attorney will also have the chance to analyze your notes, so make them as accurate as possible.

An investigator will also follow a repeatable process to ensure that no potential evidence is left unexamined. This typically includes:

- Initial Reconnaissance
- Time line creation and analysis
- File and Directory Analysis
- Data Recovery
- String Search

Regardless of what tools you use and the order you follow, your overall methodology will remain the same and must be focused on solving the case. Some investigators will start with the time line creation and analysis phase, while others might try to identify entry points first, doing a string search on known IP addresses, usernames or any other key words.

Even though there are many ways to get to the same conclusion, it is vital that both the results and the process and tools used to obtain those results are thoroughly documented and familiar to the investigator.

Listing 3. *OS version found in the SOFTWARE registry file using RegRipper*

```
----------------------------------------
WinNT_CV
Microsoft\Windows NT\CurrentVersion
LastWrite Time Sun Feb  5 22:29:17 2006 (UTC)
  RegDone :
  CurrentVersion : 5.2
  CurrentBuildNumber : 3790
  CSDBuildNumber : 1830
  SoftwareType : SYSTEM
  SourcePath : D:\I386
  RegisteredOrganization : counters
  RegisteredOwner : counters
  SystemRoot : C:\WINDOWS
  PathName : C:\WINDOWS
  CSDVersion : Service Pack 1
  CurrentType : Uniprocessor Free
  ProductId : 69763-024-0099217-43782
  InstallDate : Thu Jan 26 06:56:44 2006 (UTC)
  BuildLab : 3790.srv03_sp1_rtm.050324-1447
  ProductName : Microsoft Windows Server 2003 R2
```

Initial Reconnaissance

Our investigation starts piecing together the bits of information you already have and looking at those you might need at various points in your investigation. Those include:

- OS type and build
- Date and time settings, including timezone
- User accounts
- Environment variables
- Host firewall configuration and open ports
- Installed applications, etc...

It is known that the image we are to analyze is from a Windows 2003 Server host, as that information was already provided with Challenge description, so chances are that most of the information we need will be actually stored in the Registry. Besides the configuration information, the Windows Registry holds information regarding recently accessed files and considerable information about user activities, installed applications, system shares, audit policy, wireless SSID's, mounted devices, connections to other systems, etc.

The registry is a collection of data files that can be accessed either on a live system or off-line using *regedt32*.

Listing 4. *Excerpt of the SAM registry hive*

```
User Information
------------------------
Username        : Administrator [500]
Full Name       :
User Comment    : Built-in account for administering the
                      computer/domain
Last Login Date : Sun Feb  5 22:29:16 2006 Z

Username        : Guest [501]
Full Name       :
User Comment    : Built-in account for guest access to the
                      computer/domain
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : SUPPORT_388945a0 [1001]
Full Name       : CN=Microsoft Corporation,L=Redmond,S=Washin
                      gton,C=US
User Comment    : This is a vendor's account for the Help and
                      Support Service
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : Johnatan [1006]
Full Name       : Johnatan Tezcatlipoca
User Comment    :
Last Login Date : Sun Feb  5 20:23:09 2006 Z

Username        : ernesto [1007]
Full Name       : Ernesto Sánchez
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : amado [1008]
Full Name       : Amado Carrillo
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : maick [1009]
Full Name       : Gabriel Torres
User Comment    :
Last Login Date : Sat Feb  4 02:11:04 2006 Z

Username        : lalo [1010]
Full Name       : Eduardo Hernández
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : moni [1011]
Full Name       : Monica Islas
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : maru [1012]
Full Name       : Maria Guadalupe Ramos
User Comment    :
Last Login Date : Thu Jan 26 22:59:30 2006 Z

Username        : mirna [1013]
Full Name       : Mirna Casillas
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : katy [1014]
Full Name       : Katalina Rodriguez
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : caracheo [1015]
Full Name       : Jorge Caracheo Mota
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : ovejas [1016]
Full Name       : Eduardo Roldán
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : reno [1017]
Full Name       : Israel Robledo Gonzáles
User Comment    :
Last Login Date : Fri Feb  3 02:34:18 2006 Z

Username        : pili [1018]
Full Name       : Elizabet Herrera Zamora
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : zamorano [1019]
Full Name       : Rolando Zamorategui
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : mpenelope [1020]
Full Name       : Mari Carmen Penelope
User Comment    :
Last Login Date : Thu Jan  1 00:00:00 1970 Z

Username        : postgres [1023]
Full Name       : postgres
User Comment    : PostgreSQL service account
Last Login Date : Sat Feb  4 22:46:49 2006 Z

Username        : ver0k [1024]
Full Name
User Comment    :
Last Login Date : Sun Feb  5 20:47:21 2006 Z
```

There will be different files and different locations for these files, depending upon the version of Windows, but they are all on the local machine. Windows NT-based systems store the registry in a binary hive format, which is the same format that can be exported, loaded and unloaded by the Registry Editor in these operating systems. The following Registry files are stored in `%SystemRoot%\System32\Config\`:

- Sam – `HKEY_LOCAL_MACHINE\SAM`
- Security – `HKEY_LOCAL_MACHINE\SECURITY`
- Software – `HKEY_LOCAL_MACHINE\SOFTWARE`
- System – `HKEY_LOCAL_MACHINE\SYSTEM`
- Default – `HKEY_USERS\.DEFAULT`

In addition to those, the following file is stored in each user's profile folder:

- `%UserProfile%\Ntuser.dat` – `HKEY_USERS\<User SID>` (linked to by `HKEY_CURRENT_USER`)

While *regedt32* allows you to view and manipulate the registry, a faster, easier and better tool is available to the forensic community. That tool is *RegRipper* which is available at *www.regripper.net* and included in your forensic workstation toolset. *RegRipper* is a Windows Registry data extraction and correlation tool created and maintained by Harlan Carvey, author of the well-known and highly recommended *Windows Forensic Analysis* book. *RegRipper* uses plugins to access specific Registry hive files and extracts specific keys, values, and data, bypassing the Win32API and dumping the output in a plain text file.

To use *RegRipper* from our forensic workstation change to the directory where the off-line system is mounted, select the registry file to parse, the appropriate plugin file (i.e., SAM, security, system, software) and give it a location for the report. Therefore, to analyze the ERP's system registry file we run:

```
# perl rip.pl -r /mnt/hack/hakin9/Windows/System32/config/system -f system > /images/hakin9/system.txt
```

And here is an excerpt from its output (see Listing 1).

Based on the information provided by the *system* registry file, we can start building a system profile. In this example, we know that the computer's name is COUNTERS, it was last cleanly shutdown on Sunday, 5 Feb at 23:44, that its time zone was set to *Pacific Standard Time* (GMT-8) and that used an Intel Pentium III Processor.

The *Interfaces* key also provides useful information about the host TCP/IP configuration. We know it has two active network interfaces, one with IP address 192.168.5.5/24 and default gateway 192.168.5.254 and a second interface configured to receive a dynamic address via DHCP. Also, the *EnableFirewall* key set to 1 indicates that the host firewall was active and allowing traffic on the ports listed under the *GloballyOpenPorts\List* key. It is interesting to note that port 3389 TCP is open in the firewall, but this port is not enabled by default and allows remote access to the host via Terminal Services. It will be interesting to further investigate who activated it and when was that service activated.

We can even see the different USB devices that were attached to the computer and when were they attached.

Next, looking at the *SOFTWARE* registry file, we can extract a list of the applications installed on the system (see Listing 2).

Now we can see what the Web based ERP runs on: Apache 1.34, PHP 4.1 and MySQL 4.1. This information is valuable because it gives the investigator the opportunity to check whether these software packages are vulnerable by searching vulnerability databases like those from US-CERT, OSVDB, NIST, Mitre, Secunia and others. Also, the list of security updates will tell you if the machine is fully patched.

In addition to information related to the installed applications, the *SOFTWARE* registry file can also provide valuable information on the OS version (see Listing 3).

And particularly interesting is the info we get from the *SAM* registry hive, a file that holds the usernames and password hashes for every account on the local machine. The following is an excerpt of its content (See Listing 4).

One account stands out of the rest: *ver0k*. It is the only account that does not have either a Full Name or a Description and it is the last account created on the system. Also, its spelling suggests that it was not created by a conventional user. At this point in our investigation it is worth to start creating a *Dirty Word List*, one that is to be used in a later keyword search, and `ver0k` is no doubt a good candidate for that list.

Do not miss Part II, of this article if you want to learn how to analyze *NTUSER.DAT*, a key file in our investigation, how to use Autopsy to extract data from the filesystem to create a time line of events or how to parse Windows Event Logs and Internet Explorer's Browsing History, among others.

On The 'Net

- *http://www.seguridad.unam.mx/eventos/reto/* – UNAM-CERT Forensic challenge
- *http://sansforensics.wordpress.com/* – SANS Forensic Blog
- *http://liveview.sourceforge.net/* – LiveView
- *http://helix.e-fense.com/Download.php* – Helix CD
- *http://www.foolmoon.net/security/wft/* – Windows Forensic Toolchest
- *http://www.regripper.net/* – RegRipper
- *http://windowsir.blogspot.com/* – Windows Incident Response (Harlan Carvey's blog)
- *http://www.insectraforensics.com* – Computer Forensics eStore
- *http://www.jessland.net/JISK/Forensics/Challenges.php* – Other forensic challenges
- *http://www.forensics.nl/links* – Computer forensic links and whitepapers

Ismael Valenzuela
Since he founded G2 Security, one of the first IT Security consultancies in Spain, Ismael Valenzuela has participated as a security professional in international projects across the UK, Europe, India and Australia. He holds a Bachelor in Computer Science, is certified in Business Administration and also holds the following security related certifications: GIAC Certified Forensic Analyst, GIAC Certified Intrusion Analyst, GIAC Penetration Tester, ITIL, CISM, CISSP and IRCA ISO 27001 Lead Auditor by Bureau Veritas UK. He is also a member of the SANS GIAC Advisory Board and international BSi Instructor for ISO 27001, ISO 20000 and BS 25999 courses.
He currently works as Global ICT Security Manager at iSOFT and can be contacted through his blog at http://blog.ismaelvalenzuela.com